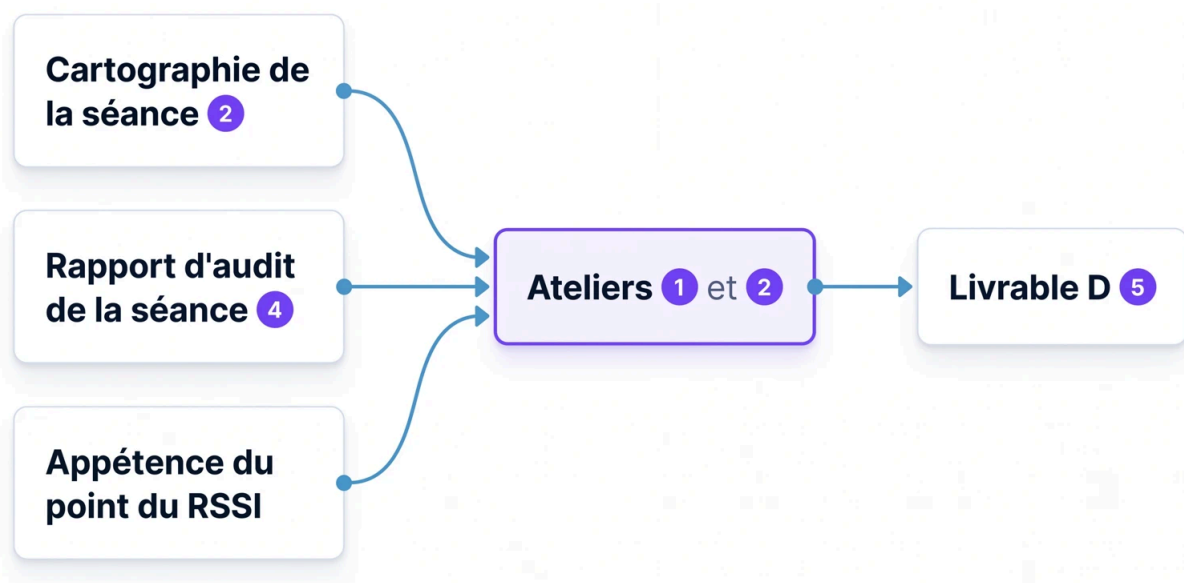


Ateliers 1 et 2 EBIOS RM : Socle et sources de risque

✓ L'étude s'ouvre : de la méthode à la table de travail



Objectifs de la séance

À l'issue de ce TD :

- **Cadrer** une étude EBIOS Risk Manager : objectif, participants et rôles, cadre temporel, responsable de l'acceptation des risques résiduels
- **Réutiliser** les valeurs métier et les biens supports de la cartographie pour délimiter le périmètre métier et technique de l'étude

- **Formuler** des événements redoutés et estimer leur gravité à partir des besoins de sécurité DICT (disponibilité, intégrité, confidentialité, traçabilité)
- **Établir** le socle de sécurité du groupe : référentiels applicables, état d'application, écarts justifiés, décision de poursuite
- **Construire** et prioriser des couples source de risque / objectif visé, puis les confronter aux événements redoutés

Prérequis

- Le cours magistral de ce matin : le vocabulaire du risque et la mécanique des cinq ateliers.
- La cartographie de la séance 2 : valeurs métier, biens supports, besoins DICT et Top 5 des actifs critiques du groupe MERIDIAN. Règle du jour : ces objets se réutilisent tels quels, dans les mêmes termes ; les recréer serait une faute de méthode.
- Le rapport d'audit de la séance 4 et ses écarts qualifiés par filiale : il devient une donnée d'entrée de l'atelier 1.
- L'appétence au risque préparée au point du RSSI de ce matin.

Le dispositif du TD

Ce TD conduit les deux premiers ateliers de la méthode sur le groupe MERIDIAN, dans l'ordre du guide et avec ses livrables. Les quatre exercices suivent les étapes réelles de l'atelier 1, cadrage, périmètre, événements redoutés, socle, puis l'atelier 2 entier. Chaque exercice produit un élément qui entrera tel quel dans le livrable D5 de fin de journée : rien de ce qui s'écrit ici n'est jetable. Les corrigés sont regroupés en fin de leçon ; le travail se fait sans eux, ils servent à confronter, pas à démarrer.

✓ Exercice 1 : cadrer l'étude avant d'analyser quoi que ce soit

L'atelier 1 commence par une étape que les débutants bâclent et que les praticiens savent décisive : le cadre. Une étude sans objectif explicite dérive ; une étude sans rôles nommés produit des conclusions que personne ne porte.

La Direction Générale du groupe MERIDIAN a validé le principe d'une appréciation des risques à l'échelle du groupe, avec un premier cycle concentré sur la filiale instruite, c'est-à-dire celle dont le groupe tient le dossier, et sur sa principale dépendance inter-filiale du S6 du dossier de filiale. Pour Santé comme pour Logistique, cette dépendance est le flux d'approvisionnement d'urgence entre les deux filiales ; pour Éducation comme pour Territoires, c'est l'annuaire d'identités commun du pôle. Le RSSI Groupe anime l'atelier de cadrage.

À produire, en quinze lignes au plus :

1. **Formuler** l'objectif de l'étude en une phrase, en choisissant parmi les finalités reconnues de la méthode celle qui correspond à la commande de la Direction Générale.
2. **Composer** la table des participants de l'atelier 1 : les quatre rôles que le guide attend, chacun incarné par un acteur de la carte du pouvoir de la filiale instruite (§3 du dossier de filiale) ou de la holding, avec pour chacun ce qu'il apporte que les autres n'ont pas.
3. **Désigner** la personne responsable d'accepter les risques résiduels au terme de l'étude, en une phrase de justification adossée à la gouvernance du groupe.
4. **Poser** le cadre temporel : la durée des deux cycles, avec la référence qui justifie ce choix.

Indice de méthode pour le point 2 : se demander qui peut dire ce qui compte pour le métier, qui peut dire ce que le SI permet, qui peut dire ce que la sécurité sait de la menace, et qui peut engager le groupe. Quatre questions, quatre chaises.

✓ Exercice 2 : du patrimoine cartographié aux événements redoutés

Le périmètre métier et technique ne s'invente pas en séance : il se reprend de la cartographie. Le matériau est celui que le groupe a produit en séance 2 pour la filiale instruite. Reprendre trois valeurs métier de cette cartographie, puis ajouter en quatrième ligne la dépendance inter-filiale du §6 du dossier de filiale. Pour chacune des quatre lignes, noter les biens supports associés et le besoin de sécurité dominant, sur le modèle : valeur métier, biens supports, besoin dominant.

Ce tableau de quatre lignes est le point de départ, pas le rendu : l'exercice consiste à le prolonger vers ce que le groupe redoute.

À produire :

1. **Formuler** six événements redoutés, au moins un par ligne du tableau, dépendance inter-filiale comprise, chacun en une expression courte qui nomme la valeur métier atteinte et le besoin de sécurité touché. Parcourir les quatre besoins DICT pour ne pas produire six variations du même événement.
2. **Coter** la gravité de chacun sur l'échelle en quatre niveaux vue en cours, de mineure à critique, en justifiant chaque cote par la nature des impacts : missions, réglementation, personnes, image.
3. **Signaler** l'événement redouté pour lequel une précision de durée change la cote, et proposer cette précision.

Indice pour le point 3 : le guide recommande, pour les atteintes à la disponibilité, de préciser au-delà de quelle perte de service le niveau de gravité est atteint. Chaque dossier de filiale porte au moins un cas de durée chiffré ; une des lignes du tableau y gagne beaucoup.

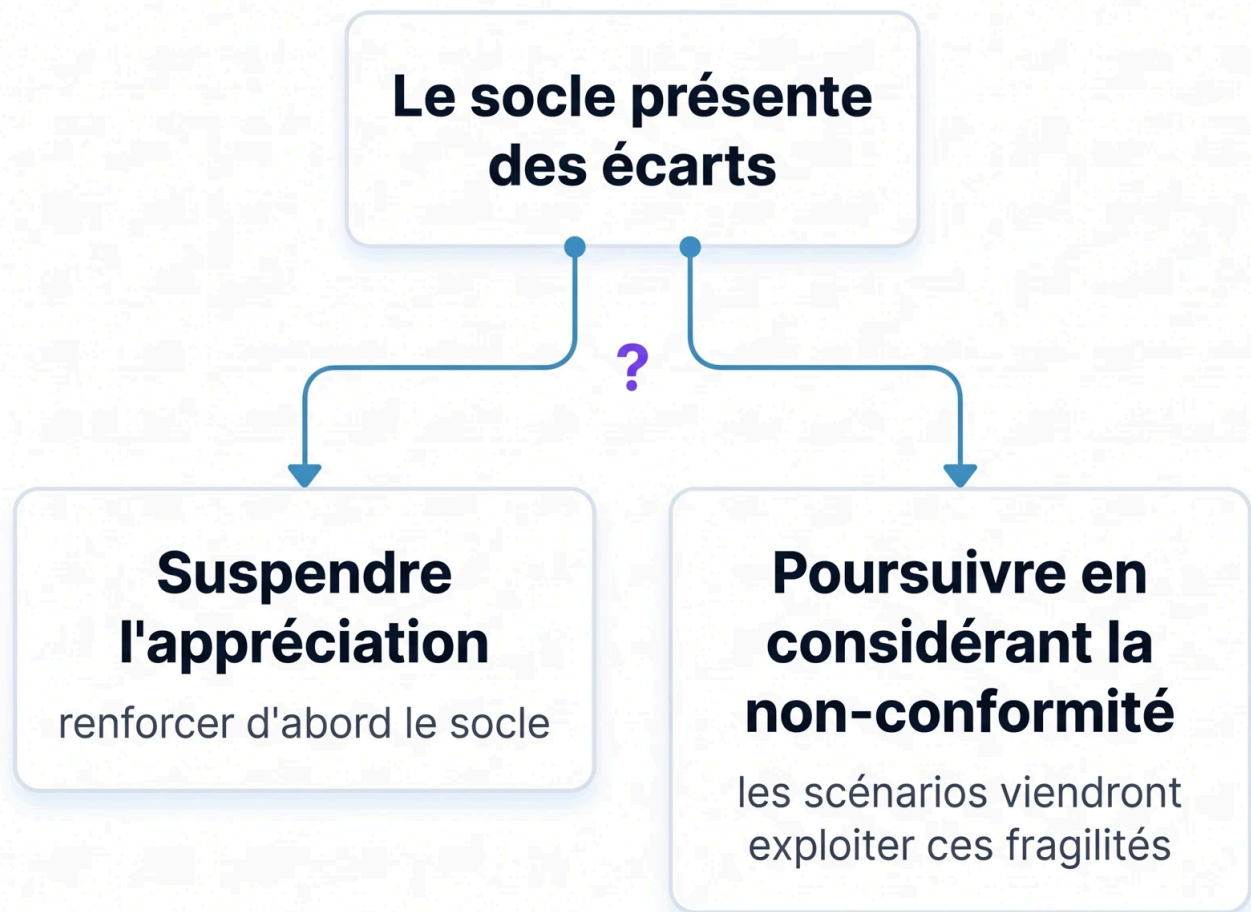
✓ Exercice 3 : le socle de sécurité, ou l'audit qui trouve sa place

L'étape D de l'atelier 1 formalise le socle de sécurité. Presque tout existe déjà : le choix de référentiel de la séance 3 et le rapport d'audit de la séance 4 sont exactement « l'état d'application » que la méthode demande. Le travail est un assemblage rigoureux, pas une nouvelle collecte.

À produire : la table du socle de sécurité du périmètre, sur le modèle du guide, avec quatre colonnes : type et nom du référentiel, état d'application, écarts, justification des écarts. Elle doit couvrir les référentiels applicables à la filiale instruite : la PSSI (politique de sécurité des systèmes d'information) cadre du groupe posée en séance 1, le guide d'hygiène informatique de l'ANSSI (Agence nationale de la sécurité des systèmes d'information), ISO/IEC 27001:2022 choisie en séance 3, et les obligations propres à la filiale telles que le 52 du dossier de filiale les liste (RGPD et hébergement de données de santé pour Santé, exigences contractuelles du client pharmaceutique pour Logistique, RGPD et données de mineurs pour Éducation, clauses des contrats de délégation et délai de notification de vingt-quatre heures pour Territoires).

Les écarts à reporter sont les deux constats du tableau du dossier de référence pour cette filiale, tels que le rapport d'audit de la séance 4 les a qualifiés. Les directives de la PSSI cadre telles que la séance 1 les a codifiées (ACC-01 à COR-01) font foi pour cet exercice, quelle que soit la rédaction retenue par le groupe.

Puis, en trois phrases : la décision de poursuite. Le guide ouvre deux voies quand le socle présente des écarts, et une seule est raisonnable ici. Laquelle, et pourquoi ? Et quelle conséquence cette décision aura-t-elle sur les ateliers suivants ?



✓ Exercice 4 : sources de risque et objectifs visés

Changement de camp. L'atelier 2 répond à la question du guide : qui ou quoi pourrait porter atteinte aux missions et valeurs métier de l'atelier 1, et dans quels buts ? Un élément de contexte pour ancrer la réflexion dans la menace réelle : l'ANSSI a eu connaissance de 128 compromissions par rançongiciel en 2025. Le secteur de la santé reste une cible régulière de ce type d'attaque, comme l'a montré en 2022 le Centre Hospitalier Sud Francilien, victime d'un rançongiciel revendiqué par le groupe LockBit.

À produire :

1. **Recenser** cinq couples source de risque / objectif visé candidats pour le périmètre de la filiale instruite, en s'appuyant sur les acteurs des §3 et §6 de son dossier et en variant les catégories de sources : cybercriminels, concurrents, activistes, collaborateurs. Pour chaque couple, une ligne : la source, son objectif visé formulé comme une finalité, et la valeur métier qu'il vise.

2. **Évaluer** la pertinence de chaque couple selon les trois critères du guide, motivation, ressources, activité, sur une échelle qualitative à trois positions, en justifiant la colonne activité par un élément observable.
3. **Sélectionner** les trois couples retenus pour la suite de l'étude, en respectant la règle de sélection du guide : des couples suffisamment distincts, qui n'impactent pas tous la même valeur métier.
4. **Confronter** les couples retenus aux événements redoutés de l'exercice 2 : construire la table de correspondance, et signaler tout événement redouté grave resté sans source de risque plausible, ou tout couple retenu sans événement redouté associé.

Piège à éviter, annoncé en cours et vérifié en corrigé : ne pas confondre l'objectif visé et la motivation. « S'enrichir » n'est pas un objectif visé, c'est ce qui pousse la source ; l'objectif visé se formule comme un résultat concret obtenu aux dépens du groupe.



Corrigés et critères d'évaluation — cliquer pour révéler